

GPO giảm thiểu mối đe dọa Lateral Movement

Lateral Movement là gì?

Lateral Movement (di chuyển ngang) là một kỹ thuật tấn công mà kẻ xâm nhập sử dụng để di chuyển từ một hệ thống ban đầu (nơi chúng đã xâm nhập thành công) sang các hệ thống khác trong mạng nội bộ. Mục tiêu chính của kỹ thuật này là:

- **Mở rộng quyền kiểm soát:** Kẻ tấn công tìm cách leo thang đặc quyền hoặc truy cập các tài khoản có quyền cao hơn.
- **Thu thập thông tin nhạy cảm:** Truy cập dữ liệu quan trọng hoặc hệ thống chủ chốt.
- **Duy trì sự hiện diện:** Thiết lập khả năng tồn tại lâu dài trong môi trường.

GPO giảm thiểu mối đe dọa Lateral Movement

Để triển khai GPO giảm thiểu mối đe dọa **Lateral Movement** một cách hiệu quả nhất, bạn cần cân nhắc các yếu tố như mục tiêu bảo mật, hiệu suất hệ thống, và khả năng quản lý log. Dưới đây là các bước và khuyến nghị cấu hình cụ thể:

1. Chống tấn công Pass-the-Hash (PTH)

- **Mục tiêu:** Ngăn chặn tấn công bằng cách lạm dụng thông tin đăng nhập đã bị đánh cắp.
- **Chức năng:**
 - Kích hoạt chế độ kiểm toán (audit mode) cho Lsass.exe.
 - Bảo vệ LSA (Local Security Authority).
- **Cấu hình:**
 - a) **Kích hoạt chế độ kiểm toán Lsass.exe**

Computer Configuration -> Policies -> Administrative Templates -> SCM: Pass the Hash Mitigations

- **Lsass.exe audit mode: Enabled** (Bật kiểm tra Lsass.exe để phát hiện hành vi khai thác).

b) Bật LSA Protection

Computer Configuration -> Policies -> Administrative Templates -> System -> Local Security Authority

- **LSA Protection: Enabled** (Bảo vệ tiến trình LSA khỏi bị khai thác trực tiếp).
- **Tại sao quan trọng?**

PTH là một kỹ thuật phổ biến để di chuyển ngang bằng cách tái sử dụng hash mật khẩu, và bảo vệ LSA sẽ giảm thiểu nguy cơ này.

2. Theo dõi thay đổi trong cấu hình và chính sách

- **Mục tiêu:** Ghi lại thay đổi trong cấu hình bảo mật và hành vi hệ thống.
- **Chức năng:**
 - Kiểm toán các thay đổi dịch vụ thư mục, chính sách bảo mật, và tích hợp hệ thống.
- **Cấu hình:**

a) Bật kiểm toán thay đổi chính sách

Computer Configuration -> Policies -> Windows Settings -> Security Settings -> Advanced Audit Policy Configuration -> Policy Change

- Bật kiểm toán cho các mục sau:
 - **Audit Policy Change:** Success.
 - **Audit MPSSVC Rule-Level Policy Change:** Success.

b) Theo dõi thay đổi dịch vụ thư mục

Computer Configuration -> Policies -> Windows Settings -> Security Settings -> Advanced Audit Policy Configuration -> DS Access

- **Audit Directory Service Changes:** Success.

• Tại sao quan trọng?

Theo dõi những thay đổi trong chính sách hoặc cấu hình hệ thống giúp phát hiện kẻ tấn công thao túng hệ thống để thuận lợi cho di chuyển ngang.

3. Theo dõi hoạt động tài khoản

- **Mục tiêu:** Theo dõi hoạt động tài khoản và các sự kiện liên quan.
- **Chức năng:**
 - Ghi nhận việc tạo, thay đổi, và quản lý tài khoản.
 - Kiểm tra hoạt động đăng nhập/đăng xuất.
- **Cấu hình:**

a) Theo dõi Kerberos

Computer Configuration -> Policies -> Windows Settings -> Security Settings -> Advanced Audit Policy Configuration -> Account Logon

- **Audit Kerberos Authentication Service:** Success & Failure.
- **Audit Kerberos Service Ticket Operations:** Success & Failure.

b) Theo dõi quản lý tài khoản

Computer Configuration -> Policies -> Windows Settings -> Security Settings -> Advanced Audit Policy Configuration -> Account Management

- **Audit User Account Management:** Success & Failure.

- **Audit Security Group Management:** Success.
- **Tại sao quan trọng?**

Kerberos thường bị khai thác trong các cuộc tấn công Lateral Movement. Việc theo dõi hoạt động xác thực và quản lý tài khoản sẽ giúp bạn phát hiện các sự kiện đáng ngờ.

4. Giám sát quyền và truy cập

- **Mục tiêu:** Kiểm soát và ghi nhận truy cập tệp, quyền hệ thống, và thao tác với đối tượng bảo mật.
- **Chức năng:**
 - Theo dõi chi tiết truy cập vào hệ thống tệp, registry, và các quyền nhạy cảm.

- **Cấu hình:**

- a) **Theo dõi hệ thống tệp và registry**

Computer Configuration -> Policies -> Windows Settings -> Security Settings -> Advanced Audit Policy Configuration -> Object Access

- **Audit File System:** Success & Failure ((giới hạn theo thư mục quan trọng).
- **Audit Registry:** Success & Failure.

- b) **Theo dõi quyền đặc biệt**

Computer Configuration -> Policies -> Windows Settings -> Security Settings -> Advanced Audit Policy Configuration -> Privilege Use

- **Audit Sensitive Privilege Use:** Success & Failure.

- **Lưu ý:**
 - Vì "**Audit File System**" có thể tạo ra lượng log lớn, chỉ áp dụng cho các thư mục quan trọng (ví dụ: thư mục chứa dữ liệu bảo mật hoặc thông tin cấu hình hệ thống).
- **Tại sao quan trọng?**

Theo dõi việc truy cập tệp nhạy cảm và registry giúp phát hiện hành vi lạm dụng quyền hoặc sửa đổi trái phép.

5. Theo dõi tiến trình và PowerShell

- **Mục tiêu:** Theo dõi và ghi lại quá trình tạo/lưu/hoạt động của các tiến trình.
- **Chức năng:**
 - Bật kiểm toán chi tiết cho tiến trình.
 - Ghi nhận lệnh chạy qua PowerShell.

- **Cấu hình:**

- a) **Theo dõi tiến trình**

Computer Configuration -> Policies -> Administrative Templates -> System -> Audit Process Creation

- **Audit Process Creation:** Success (bao gồm cả dòng lệnh - bật Include command line in process creation events).

- b) **Ghi log PowerShell**

Computer Configuration -> Policies -> Administrative Templates -> Windows Components -> Windows PowerShell

- **PowerShell Logging:**
 - **Turn on Module Logging:** Enabled (ghi log cho tất cả các module bằng wildcard *).
 - **Turn on PowerShell Script Block Logging:** Enabled.
 - **Tại sao quan trọng?**

PowerShell là công cụ phổ biến được tin tặc sử dụng cho di chuyển ngang. Theo dõi tiến trình và ghi log lệnh PowerShell giúp bạn phát hiện hành vi bất thường.

6. Tối ưu hóa log và hiệu năng

- **Tối ưu hóa log:**

Computer Configuration -> Policies -> Windows Settings -> Security Settings -> Event Log

- **Kích thước log:** Tăng kích thước lưu trữ log trên các hệ thống quan trọng (ví dụ: tối thiểu 500 MB cho Security Log).

Computer Configuration -> Policies -> Windows Settings -> Security Settings -> Event Log -> Maximum log size.

- **Log rotation:** Bật cơ chế tự động ghi đè log cũ để đảm bảo không bị mất dữ liệu.

- **Giảm nhiễu (noise):**

- Chỉ áp dụng kiểm toán tệp và registry cho các mục tiêu cụ thể, thay vì bật toàn hệ thống.
- Sử dụng công cụ SIEM (Security Information and Event Management) để hợp nhất và phân tích log.

7. Chính sách nâng cao khác

- **Phân vùng GPO theo nhóm hệ thống:**

- Phân chia GPO thành các đơn vị OU (Organizational Units) dựa trên chức năng (ví dụ: máy chủ quan trọng, máy tính người dùng).

- **Bảo vệ chính sách GPO:**

- Đảm bảo chính sách GPO không bị sửa đổi trái phép bằng cách hạn chế quyền truy cập và sử dụng chế độ kiểm toán cho việc thay đổi GPO.

Ví dụ thực tế: Tấn công Lateral Movement trong Active Directory

Tình huống:

Một nhân viên của công ty XYZ vô tình tải xuống một tệp đính kèm độc hại từ email lừa đảo (phishing). Kẻ tấn công lợi dụng mã độc trong tệp đính kèm để chiếm quyền truy cập vào máy tính của nhân viên này, được gọi là **máy "nạn nhân ban đầu"**.

Kịch bản tấn công Lateral Movement:

1. Giai đoạn 1: Khai thác thông tin trên máy nạn nhân ban đầu

- Kẻ tấn công sử dụng công cụ **Mimikatz** để trích xuất thông tin xác thực (credential) của tài khoản đã đăng nhập trên máy này.
- Kẻ tấn công phát hiện tài khoản thuộc nhóm có quyền truy cập mạng nội bộ.

2. Giai đoạn 2: Di chuyển ngang sang máy khác

- Kẻ tấn công thực hiện **Pass-the-Hash** bằng cách sử dụng hash mật khẩu trích xuất từ tài khoản đã thu thập.
- Với hash này, kẻ tấn công đăng nhập từ xa vào một máy chủ tệp (file server) trong mạng nội bộ.

3. Giai đoạn 3: Leo thang đặc quyền

- Trên máy chủ tệp, kẻ tấn công phát hiện một tài khoản Domain Admin đã đăng nhập trước đó (ví dụ: qua Event Viewer hoặc bộ nhớ).
- Kẻ tấn công sử dụng **Pass-the-Ticket** để tạo vé Kerberos giả, cho phép chúng hành động với quyền Domain Admin.

4. Giai đoạn 4: Xâm nhập các hệ thống quan trọng

- Kẻ tấn công sử dụng quyền Domain Admin để:
 - Truy cập máy chủ cơ sở dữ liệu chứa thông tin nhạy cảm (như thông tin khách hàng).

- Thay đổi chính sách GPO để tắt kiểm tra log (log auditing) nhằm che giấu dấu vết.
- Tạo người dùng backdoor để duy trì quyền truy cập dài hạn.

Ứng dụng các biện pháp phòng ngừa trong tình huống này:

1. Bảo vệ tiến trình LSA và kiểm toán Pass-the-Hash:

- Bật **LSA Protection** để ngăn chặn trích xuất thông tin đăng nhập từ bộ nhớ.
- Kích hoạt log kiểm toán cho **Audit Process Creation** và theo dõi mọi tiến trình sử dụng Mimikatz.

2. Kiểm toán Kerberos và quản lý tài khoản:

- Theo dõi chặt chẽ các sự kiện **Audit Kerberos Authentication Service** để phát hiện việc sử dụng vé Kerberos giả mạo.
- Cấu hình **Audit User Account Management** để ghi nhận mọi thay đổi tài khoản bất thường.

3. Hạn chế di chuyển ngang:

- Cấu hình **Audit File System** trên máy chủ tệp để ghi nhận các truy cập bất thường vào các tệp quan trọng.
- Giới hạn quyền truy cập RDP hoặc SMB bằng cách áp dụng chính sách GPO cho từng nhóm máy tính.

4. Giám sát log và sử dụng công cụ SIEM:

- Tích hợp log từ AD, Kerberos, và các dịch vụ khác vào hệ thống SIEM.
- Cảnh báo theo thời gian thực khi phát hiện hành vi đáng ngờ, như việc tạo vé Kerberos mới hoặc đăng nhập từ các IP không quen thuộc.

Lời khuyên:

Lateral Movement là một trong những kỹ thuật tấn công nguy hiểm, đặc biệt trong môi trường Active Directory. Để bảo vệ hệ thống, hãy đảm bảo rằng bạn thực hiện đầy đủ các bước cấu hình GPO như đã hướng dẫn, đồng thời kết hợp với các biện pháp sau:

1. **Giám sát thường xuyên:** Sử dụng công cụ SIEM hoặc các giải pháp giám sát log tập trung để phát hiện và phản ứng kịp thời trước các sự kiện đáng ngờ.
2. **Bảo mật thông tin đăng nhập:** Áp dụng các cơ chế bảo vệ như Credential Guard, hạn chế sử dụng tài khoản Domain Admin và thực hiện chính sách mật khẩu mạnh.
3. **Kiểm tra định kỳ:** Thực hiện các bài kiểm tra bảo mật và đánh giá cấu hình GPO để đảm bảo hệ thống luôn được bảo vệ tối ưu.
4. **Đào tạo nhân viên:** Nâng cao nhận thức về các kỹ thuật tấn công và bảo mật trong toàn bộ tổ chức.

Nhớ rằng, bảo mật là một hành trình liên tục, không phải là đích đến. Sự kết hợp giữa các cấu hình kỹ thuật và quản lý con người sẽ tạo ra một hệ thống phòng thủ toàn diện.

Website: <https://quantribaomat.com/>

Telegram Group: @QuanTriBaomat

Telegram Channel: @AdSecVN

Facebook Fanpage: <https://www.facebook.com/AdSecVN>

Facebook Group: <https://www.facebook.com/groups/AdSecVN>